SLIDE 01 • EXECUTIVE OVERVIEW

AEGIS: The Financial Black Box for AI Agents

Deterministic Spending Governance, Multi-Rail Execution & Cryptographic Forensic Provenance

THE CORE AXIOM: "NEVER ALLOW AN LLM TO APPROVE ITS OWN MONEY"

Autonomous agents represent trillions in impending economic activity, but legacy payment gateways were built exclusively for human sessions with static cards. AEGIS provides deterministic governance, serializable advisory locks, Merkle hash chains, and automated dispute defense.

100%
DETERMINISTIC CONTROL
Zero LLM Fund Authorizations

SHA-256
MERKLE PROVENANCE
Tamper-Evident Hash Chains

Orders v2
PAYPAL SANDBOX RAIL
Live Multi-Rail REST Execution

96.0 / 100
AUDIT MATURITY SCORE
354 Automated Suites Passing

Verified Live Production Credentials (Worldwide Access)

- Web Console: https://aegis-staging.abhinavkumarsingh.tech/login • REST API / Docs: https://api-staging.abhinavkumarsingh.tech/docs
- Evaluator Login: chief-auditor-bf1ab00d@aegis-nexus.tech • Password: SuperSecurePassword123!@#
- Azure Ubuntu VM: 20.124.91.36 (Port 443 TLS) • Tenant UUID: 829db6b0-6566-4d6d-84e7-6fae90633723

Why Legacy Payment Rails Fail Autonomous AI Agents

5 Structural Vulnerabilities When Non-Deterministic LLMs Interface with Corporate Cards

1. Unbounded Spending Loops

When an autonomous agent is caught in an error-recovery, recursive retry, or search loop, programmatic card requests can drain corporate limits in minutes without human detection.

2. Prompt Injection Exploits

Adversarial inputs on merchant websites or indirect prompt injections manipulate LLM decision-making into approving fraudulent, unauthorized, or inflated transactions.

3. Concurrency & Double-Spend Races

Independent agent worker threads operating concurrently execute simultaneous checkouts that bypass optimistic balance checks, resulting in negative ledger balances.

4. Zero Audit Provenance

Standard HTTP logs capture timestamps and IP addresses but cannot explain *why* an agent made a decision, rendering forensic root-cause analysis impossible.

Result: Payment processors hold merchants and enterprises strictly liable. Without cryptographic proof connecting agent intent to fulfillment, chargebacks are lost automatically.

Architectural Comparison: AEGIS vs. Legacy Rails

Why Traditional Gateways and Virtual Cards Fall Short for Autonomous Workloads

Dimension	Legacy Gateways (Stripe/PayPal)	Virtual Cards (Brex/Ramp)	AEGIS Platform
Spending Governance	None (Static card limit)	Static monthly spend cap	**Deterministic Passports & Dynamic Velocity Limits**
Authorization Model	Card swipe releases funds	Basic merchant category code	**Deterministic Policy Engine (Zero LLM Authorization)**
Concurrency Control	Optimistic (Race vulnerable)	Gateway balance check	**PostgreSQL Advisory Locks (pg_advisory_xact_lock)**
Forensic Auditability	Plaintext HTTP server logs	Monthly statement CSV	**SHA-256 Merkle Hash-Chained Audit Ledger**
Dispute Defense	Manual 14-day upload forms	Manual claim receipt review	**Automated Contradiction Matrix with Telemetry Citations**
Prompt Injection	N/A (Built for human UI)	None (Agent controls browser)	**Strict XML Delimitation & Fail-Closed Rule Fallback**

SLIDE 04 • SYSTEM TOPOLOGY & DECOMPOSITION

The Tri-Subsystem Model: Guardian, GhostPay & DisputeOS

Sovereign Subsystems Governing the Complete Autonomous Transaction Lifecycle

1. AgentPay Guardian

AUTONOMOUS GOVERNANCE & EXECUTION

- Deterministic Spending Passports with tiered budgets.
- Velocity caps & mandatory human escalation thresholds.
- Atomic ledger budget reservation with advisory locks.
- PayPal Orders v2 sandbox integration with capture guards.

2. GhostPay Forensics

IMMUTABLE AUDIT & FORENSIC REPLAY

- Cryptographic SHA-256 Merkle hash-chained ledger.
- Deterministic replay simulator for past transaction states.
- Counterfactual policy simulator ('What-if' risk bounds).
- Agent DNA profiling for behavioral drift & anomaly detection.

3. DisputeOS Engine

CHARGEBACK DEFENSE & EVIDENCE GRAPHS

- Automated dispute case assembly via PayPal webhooks.
- Multimodal evidence graph (server telemetry, delivery ARNs).
- Contradiction detection cross-referencing claims with logs.
- Grounded AI defense briefs with 100% citation confidence.

Level 0 Context & Level 1 System Data Flow

Traceability from Agent Proposal Submission to Immutable Ledger Settlement

Level 0 Context Data Flow (System Boundary)

Autonomous AI Agent

Submits purchase proposal with quote items

AEGIS Platform

Enforces policy bounds & advisory locks

Human Approver

Digital sign-off on out-of-policy requests

PayPal Sandbox Rail

Creates Orders v2 & executes capture

GhostPay Ledger

Appends SHA-256 Merkle audit proof

Level 1 Decomposed Pipeline Architecture

1. Ingestion Pipeline

FastAPI router validates Pydantic v2 schemas and computes deterministic quote hash.

2. Policy Evaluation

Evaluates velocity caps and single-tx limits against spending passport constraints.

3. Concurrency Lock

Acquires pg_advisory_xact_lock on passport UUID, preventing double-spend.

4. Payment Rail Dispatch

Invokes PayPal REST v2 API with idempotency key, creating sandbox order.

5. Merkle Event Chaining

Transactional outbox worker commits event to SHA-256 Merkle audit chain.

SLIDE 06 • PROTOCOL EXECUTION SEQUENCE

End-to-End Autonomous Transaction Protocol

Proposal Validation, Advisory Locking, PayPal Order Creation, Premature Capture Guard & Settlement

Step 1: Proposal & Quote Normalization

Agent submits purchase proposal. AEGIS computes deterministic quote hash H_quote = SHA-256(canonical_json(quote_items)).

Step 2: Deterministic Policy Evaluation

Evaluates spending velocity, merchant allowlist, and per-tx limits. If proposal <= threshold ($15 < $25), auto-approves to CHECKOUT_READY.

Step 3: Human Escalation Gate

If proposal > threshold ($750 > $500), execution halts in AWAITING_APPROVAL until digital owner sign-off.

Step 4: Atomic Budget Reservation

Executes SELECT pg_advisory_xact_lock(hashtext(passport_id)) and commits balance reservation in Neon PostgreSQL.

Step 5: PayPal Orders v2 Dispatch

Creates live PayPal Sandbox order (e.g. 6A285669PT3485328). Enforces capture guard: premature capture returns 409 Conflict.

Step 6: HMAC Webhook & Merkle Settlement

Inbound webhook verified via HMAC-SHA256 fail-closed signature. Settles ledger and chains event in GhostPay audit ledger.

Mathematical Invariants & Distributed State Guarantees

Eliminating Non-Determinism, Race Conditions, and Data Loss in Agentic Finance

1. Serializable Concurrency Isolation

- SQL: SELECT pg_advisory_xact_lock(hashtext(:passport_id));
- Eliminates race conditions across distributed microservices.
- 18 automated multithreaded test suites verify zero double-spend.
- PostgreSQL row-level lock released automatically upon transaction commit.

2. Two-Phase Budget Reservation

- Formula: Available = Budget - (Settled + Reserved)
- Budget is atomically reserved BEFORE external API dispatch.
- Rolls back cleanly without balance leakage if upstream order expires.
- Guarantees that active agent swarms never drive balances negative.

3. Cryptographic Quote Normalization

- Formula: H_quote = SHA-256(canonical_json(quote_items))
- Ensures quote evaluated by policy is bit-for-bit identical to checkout.
- Protects against price drift, hidden fees, and payload tampering.
- Serialized using sorted keys and IEEE-754 decimal precision.

4. Transactional Outbox Pattern

- State mutation and event dispatch commit in the SAME transaction.
- Background worker polls outbox with exponential backoff.
- Guarantees exactly-once event delivery to Merkle ledger.
- Eliminates dual-write inconsistencies between Postgres and Redis.

Enterprise Security Architecture & STRIDE Threat Analysis

Hardened Defense-in-Depth Against Adversarial Agent Prompts and Financial Exploits

SPOOFING

Asymmetric JWT & Scoped API Keys. Strict tenant_id isolation enforced on every query.

TAMPERING

SHA-256 Merkle hash-chaining: H_n = SHA-256(H_{n-1} || E_n) detects any historical write.

REPUDIATION

Digital owner signatures logged with actor_id, correlation_id, and immutable timestamps.

INFO DISCLOSURE

PII/PCI scrubbing on quote descriptions; non-reversible tokenization of PayPal receivers.

DENIAL OF SERVICE

Upstash Redis distributed token-bucket rate limiter per agent UUID and client IP.

ELEVATION OF PRIVILEGE

Prompt Injection Defense: Model tokens stripped; external data isolated in strict XML.

Prompt Injection Sanitization & Fail-Closed Guard

- XML Delimitation: All untrusted strings are enclosed inside <untrusted_input trust="UNTRUSTED_DATA"> with angle brackets escaped.
- Zero LLM Financial Authority: LLMs generate summary text but CANNOT approve budgets, override limits, or invoke capture.
- Fail-Closed LLM Fallback: If an upstream LLM experiences 429 quota limits or prompt anomalies, DisputeOS automatically degrades to deterministic-rules-v1 with 100% uptime.

GhostPay: Deterministic Replay & Counterfactual Simulation

Reconstructing Agent Execution Timelines with Mathematical Verifiability

1. Merkle Hash-Chained Ledger

Every state mutation computes: H_n = SHA-256(H_{n-1} || canonical_json(E_n)). Bitwise alterations break chain integrity instantly, exposing unauthorized writes.

2. Deterministic Replay Simulator

Re-executes historical agent inputs, policy constraints, and quote hashes to mathematically prove that past decisions strictly complied with governance policies.

3. Counterfactual Policy Simulator

Reruns past agent transactions against *new* hypothetical policies (e.g., testing a $750 GPU charge against a $500 cap) to proactively calibrate risk thresholds.

4. Agent DNA Behavioral Profiling

Continuously tracks spending velocity, merchant categorization, and invocation timeframes, automatically alerting on anomalous drift and credential compromise.

Verified Live Proof: Investigation 4cce42a3-881d-43d7-aae5-3f32537c97eb confirmed status VALID across 5 sequential event blocks (PROPOSAL_SUBMITTED -> POLICY_EVALUATED -> BUDGET_RESERVED -> PAYPAL_ORDER_CREATED -> CAPTURE_COMPLETED).

SLIDE 10 • DISPUTE RESOLUTION & CHARGEBACK DEFENSE

DisputeOS: Automated Evidence Graphs & Contradiction Defense

Eliminating Chargeback Losses via Multimodal Telemetry and Grounded Citations

1. Automated Evidence Ingestion

Automatically ingests server access logs, API consumption telemetry, signed delivery receipts, and carrier tracking IDs upon dispute notification from PayPal.

2. Contradiction Detection Engine

Cross-references buyer dispute claims against technical telemetry. Flags direct logical contradictions (e.g. buyer claims non-delivery, but telemetry shows active API consumption).

3. Grounded AI Defense Briefs

Compiles structured chargeback defense packets with verified source citations, confidence scores, and strict rejection of ungrounded model hallucinations.

4. Human Reviewer Governance

Defense briefs require compliance officer review and digital sign-off before electronic transmission to card networks, ensuring 100% human accountability.

Verified Live Dispute Case b4502263: Buyer claimed 'Item Not Received' for 2.5M Token Batch Capacity. Contradiction Engine matched openai_workspace_quota_telemetry.json proving 42.8% token consumption within 14 mins of order settlement.

Measured Production Evidence & Commercial Roadmap

Rigorous Empirical Verification, Latency SLAs, and Enterprise Scaling Milestones

354 / 354
AUTOMATED TESTS
90%+ Statement Coverage

8 / 8
LIVE CLOUD SUITES
100% Staging Verification

< 45ms
POLICY LATENCY SLA
Strict P99 Response Time

0
CONCURRENCY DEADLOCKS
18 Multi-Thread Stress Runs

Live Staging Cloud Topology (Azure, Neon, Upstash, PayPal)

- Azure Ubuntu Staging VM (20.124.91.36): Nginx SSL reverse proxy, Docker Compose container stack.
- Neon Serverless PostgreSQL (Ohio v18.6): SSL connection pooler, SQLAlchemy 2.0 ORM, Alembic migrations.
- Upstash Managed Redis (v8.4.0 TLS rediss://): Token-bucket rate limiting, distributed caching, worker queues.
- PayPal Sandbox Orders v2: Real REST OAuth token rotation, order capture guards, fail-closed webhook security.

Strategic Commercial Roadmap (2027)

Q1 2027: Multi-Rail Expansion
Stripe Agentic & Virtual Card issuing integration; Adyen & Visa B2B connectors.

Q2 2027: Enterprise Compliance
SOC 2 Type II certification; ISO 27001 audit; Splunk / Datadog audit apps.

Q3 2027: Swarm Consensus
Multi-agent collaborative spending pools with threshold cryptographic keys.

Q4 2027: Sovereign Cloud
Enterprise On-Premises & Sovereign Cloud Helm Kubernetes packaging.